정보보호 및 개인정보보호 관리체계 인증 등에 관한 고시

[시행 2024. 7. 24.] [개인정보보호위원회고시 제2024-8호, 2024. 7. 24., 일부개정]

[시행 2024. 7. 24.] [과학기술정보통신부고시 제2024-30호, 2024. 7. 24., 일부개정]

개인정보보호위원회(자율보호정책과), (02-2100-3048
과학기술정보통신부(사이버침해대응과), 044-202-6463

제1장 총칙

제1조(목적) 이 고시는「정보통신망 이용촉진 및 정보보호 등에 관한 법률」(이하 "정보통신망법"이라 한다) 제47조제3항・제4항, 같은 법 시행령 제47조부터 제53조의2까지의 규정 및 같은 법 시행규칙 제3조에 따른 정보보호 관리체계 인증과,「개인정보 보호법」제32조의2, 같은 법 시행령 제34조의2부터 제34조의8까지의 규정에 따른 개인정보보호 인증의 통합 운영에 필요한 사항을 정하는 것을 목적으로 한다.

제2조(정의) 이 고시에서 사용하는 용어의 뜻은 다음 각 호와 같다.

1. "정보보호 및 개인정보보호 관리체계 인증"이란 인증 신청인의 정보보호 및 개인정보보호를 위한 일련의 조치와 활동이 인증기준에 적합함을 한국인터넷진흥원(이하 "인터넷진흥원"이라 한다) 또는 인증기관이 증명하는 것을 말한다.
2. "정보보호 관리체계 인증"이란 인증 신청인의 정보보호 관련 일련의 조치와 활동이 인증기준에 적합함을 인터넷진흥원 또는 인증기관이 증명하는 것을 말한다.
3. "인증기관"이란 인증에 관한 업무를 수행할 수 있도록 정보통신망법 제47조제6항,「개인정보 보호법 시행령」제34조의6제1항제2호 및 제2항에 따라 과학기술정보통신부장관과 개인정보 보호위원회(이하 "보호위원회"라 한다)가 지정하는 기관을 말한다.
4. "심사기관"이란 인증심사 업무를 수행할 수 있도록 정보통신망법 제47조제7항,「개인정보 보호법 시행령」제34조의6제1항제2호 및 제2항에 따라 과학기술정보통신부장관과 보호위원회가 지정하는 기관을 말한다.
5. "업무수행 요건・능력 심사"란 인증기관 또는 심사기관으로 지정받고자 신청한 법인 또는 단체의 업무수행 요건・능력을 심사하는 것을 말한다.
6. "인증심사"란 신청기관이 수립하여 운영하는 관리체계가 인증기준에 적합한지의 여부를 인터넷진흥원・인증기관 또는 심사기관(이하 "심사수행기관"이라 한다)이 서면심사 및 현장심사의 방법으로 확인하는 것을 말한다.
7. "인증위원회"란 인터넷진흥원 또는 인증기관의 장이 인증심사 결과 등을 심의・의결하기 위해 설치・운영하는 기구로서 위원장과 위원으로 구성된다.
8. "인증심사원"이란 인터넷진흥원으로부터 인증심사를 수행할 수 있는 자격을 부여받고 인증심사를 수행하는 자를 말한다.

8의2. "심사팀장"이란 인증심사를 수행하기 위해 구성한 팀의 책임자를 말한다.

9. "최초심사"란 처음으로 인증을 신청하거나 인증범위에 중요한 변경이 있어서 다시 인증을 신청한 때 실시하는 인증심사를 말한다.

10. "사후심사"란 인증(인증이 갱신된 경우를 포함한다)을 받고난 후 매년 사후관리를 위하여 실시하는 인증심사를 말한다.

11. "갱신심사"란 유효기간 만료로 유효기간 갱신을 위해 실시하는 인증심사를 말한다.

제3조(적용범위) 이 고시는 정보보호 및 개인정보보호 관리체계 인증, 정보보호 관리체계 인증에 공통으로 적용하되, 각 인증에 따로 적용되는 내용이 있는 경우 별도 조항으로 정한다.

제2장 정보보호 및 개인정보보호 관리체계 인증 협의회

제4조(협의회의 구성) ① 과학기술정보통신부장관과 보호위원회는 정보보호 및 개인정보보호 관리체계 인증 운영에 관한 정책 사항을 협의하기 위하여 정보보호 및 개인정보보호 관리체계 인증 협의회(이하 "협의회"라 한다)를 운영한다.

② 협의회 위원은 과학기술정보통신부과 보호위원회 소속의 인증업무를 담당하는 부서의 장으로 한다.

③ 협의회 운영을 위하여 인터넷진흥원의 인증업무를 담당하는 부서의 장을 간사로 두며, 간사는 회의에 참석하여 발언할 수 있다.

제5조(협의회의 운영) ① 협의회는 정보보호 및 개인정보보호 관리체계 인증제도와 관련하여 다음 각 호의 사항을 협의한다.

1. 인증제도 연구 및 개선에 관한 사항
2. 인증제도 운영을 위한 제반사항 검토 및 품질관리에 관한 사항
3. 인증기관 및 심사기관의 지정·재지정 및 업무정지·지정 취소에 관한 사항
4. 인증기관 및 심사기관의 관리·감독에 관한 사항
5. 인증제도 운영에 따른 민원 처리 및 법적 분쟁에 관한 사항
6. 그 밖에 협의가 필요한 사항

② 협의회는 과학기술정보통신부장관 또는 보호위원회의 요구가 있거나 협의안건이 발생한 경우 개최할 수 있다.

③ 인터넷진흥원은 협의회 개최 및 제1항 각 호에 따른 협의회 운영 업무를 지원할 수 있다.

④ 협의회는 필요하다고 인정하는 때에는 관계기관의 공무원 및 임·직원, 그 밖의 전문가를 협의회에 참석하게 하여 그 의견을 들을 수 있다.

⑤ 협의회는 협의회의 운영을 위한 별도의 규정을 정할 수 있다.

제3장 인증기관 및 심사기관

제6조(지정공고) ① 과학기술정보통신부장관과 보호위원회는 인증기관을 지정할 필요가 있는 때에는 협의회에서 지정대상 기관의 수, 업무의 범위, 신청방법 등을 미리 협의하고, 관보 또는 인터넷 홈페이지에 20일 이상 공고하여야 한다.

② 제1항에 따라 인증기관으로 지정받으려는 자는 다음 각 호의 서류를 과학기술정보통신부장관과 보호위원회에 제출하여야 한다.

1. 별지 제1호서식의 인증기관·심사기관 지정 신청서
2. 별지 제2호서식의 인증심사 업무를 수행하는 직원 보유현황과 이를 증명할 수 있는 서류
3. 별표 1의 업무수행 요건·능력 심사 제출서류

③ 심사기관 지정 신청일을 기준으로 다음 각 호의 어느 하나에 해당하는 자는 심사기관으로 지정받을 수 없다.

1. 최근 6개월 이내에 제7조제2항에 따른 심사에서 지정기준을 충족하지 못한 자
2. 최근 1년 이내에 정보통신망 제47조의2제1항에 따라 지정이 취소된 자

④ 과학기술정보통신부장관과 보호위원회는 인증기관 또는 심사기관의 지정, 재지정, 사후관리 등에 따른 업무를 인터넷진흥원에 위탁할 수 있다.

제7조(지정기준 및 지정절차) ① 인증기관 또는 심사기관의 업무수행 요건·능력 심사에 관한 세부기준은 별표 2와 같다.

② 과학기술정보통신부장관과 보호위원회는 제6조제2항에 따라 인증기관 또는 심사기관의 지정 신청을 받은 때에는 제1항에 따른 업무수행 요건·능력을 심사한다.

③ 과학기술정보통신부장관과 보호위원회는 제2항에 따른 심사 결과를 바탕으로 협의하여 인증기관 또는 심사기관으로의 지정여부를 최종 결정한다.

④ 과학기술정보통신부장관과 보호위원회는 인증기관으로 지정된 신청기관에 별지 제3호서식 정보보호 및 개인정보보호 관리체계 인증기관 지정서를, 심사기관으로 지정된 신청기관에 별지 제4호서식 정보보호 및 개인정보보호 관리체계 심사기관 지정서를 발급한다.

⑤ 과학기술정보통신부장관과 보호위원회는 제4항에 따라 지정서를 발급받은 자를 관보 또는 인터넷 홈페이지에 공고하여야 한다.

제8조(인증기관 및 심사기관의 사후관리) ① 인증기관과 심사기관은 매년 1월 31일까지 다음 각 호의 서류를 작성하여 과학기술정보통신부장관과 보호위원회에 제출하여야 한다.

1. 별지 제5호서식의 인증실적 보고서(해당 시)
2. 별지 제6호서식의 인증심사실적 보고서(해당 시)

② 과학기술정보통신부장관과 보호위원회는 필요한 경우 인증기관 또는 심사기관이 지정기준에 적합한지 여부의 확인을 위해 자료요청 또는 현장실사를 할 수 있다.

③ 과학기술정보통신부장관과 보호위원회는 제2항에 따른 지정기준의 충족여부 심사, 자료제출 요구 또는 현장심사에 관한 업무를 인터넷진흥원에 위탁할 수 있다.

④ 과학기술정보통신부장관과 보호위원회는 사후관리 결과 지정기준의 충족여부 등에 결격사유가 확인될 경우 보완을 요구할 수 있다.

제9조(인증기관 및 심사기관의 재지정) ① 인증기관 및 심사기관 지정의 유효기간은 3년이며 유효기간이 끝나기 전 6개월부터 끝나는 날까지 재지정을 신청을 할 수 있으며 제6조제2항 각 호의 서류를 과학기술정보통신부장관과 보호위원회에 제출하여야 한다. 이 경우 재지정의 신청에 대한 처리결과를 통지받을 때까지는 그 지정이 계속 유효한 것으로 본다.

② 과학기술정보통신부장관과 보호위원회는 제1항에 따른 재지정 신청을 받은 때에는 별표 2 업무수행 요건·능력 심사에 관한 세부기준에 따른 적합 여부를 심사하여 신청을 받은 날부터 3개월 이내에 그 결과를 신청기관에 통지하고, 인증기관 또는 심사기관으로 지정되는 신청기관에 제7조제4항의 지정서를 발급하여야 한다.

③ 인증기관 또는 심사기관이 재지정을 신청하지 않고 유효기간이 경과한 때에는 인증기관 또는 심사기관의 효력은 상실된다.

제10조(공정성 및 독립성 확보) 인증기관 및 심사기관은 인증심사의 공정성 및 독립성 확보를 위해 다음 각 호의 행위가 발생되지 않도록 노력하여야 한다.

1. 정보보호 및 개인정보보호 관리체계 구축과 관련된 컨설팅 업무를 수행하는 행위
2. 정당한 사유 없이 인증절차, 인증기준 등의 일부를 생략하는 행위
3. 조직의 이익 등을 위해 인증심사 결과에 영향을 주는 행위
4. 그 밖에 인증심사의 공정성 및 독립성을 훼손할 수 있는 행위

제11조(인증기관 및 심사기관의 지정취소 등) ① 인증기관 및 심사기관이 다음 각 호의 어느 하나에 해당하면 그 지정을 취소하거나 1년 이내의 기간을 정하여 해당 업무의 전부 또는 일부의 정지를 명할 수 있다. 다만, 제1호나 제2호에 해당하는 경우에는 그 지정을 취소하여야 한다.

1. 거짓이나 그 밖의 부정한 방법으로 인증기관 또는 심사기관의 지정을 받은 경우
2. 업무정지 기간 중에 인증 또는 인증심사를 한 경우
3. 정당한 사유 없이 인증 또는 인증심사를 하지 아니한 경우
4. 정보통신망법 제47조제11항 및「개인정보보호법」제32조의2제5항을 위반하여 인증 또는 인증심사를 한 경우
5. 정보통신망법 제47조제12항 및「개인정보보호법 시행령」제34조의6제1항제2호에 따른 지정기준에 적합하지 아니하게 된 경우

② 지정취소 및 업무정지에 대해서는「정보통신망 이용촉진 및 정보보호 등에 관한 법률 시행령」(이하 "정보통신망법 시행령"이라 한다) 제54조에 따른 지정취소 및 업무정지에 관한 행정처분의 기준을 따른다.

③ 과학기술정보통신부장관과 보호위원회는 제1항에 따라 지정을 취소하거나 업무정지를 명한 사실을 관보 또는 인터넷 홈페이지에 공고 하여야 한다.

제4장 인증심사원

제12조(인증심사원의 자격 요건 등) 인증심사원은 심사원보, 심사원, 선임심사원으로 구분하며 등급별 자격 요건은 별표 3과 같다.

제13조(인증심사원 자격 신청) ① 인증심사원 자격을 신청하고자 하는 자는 별표 4의 인증심사원 자격 신청 요건을 갖추고 인터넷진흥원이 공고하는 신청기간 내에 별지 제7호 서식의 인증심사원 자격 신청서와 관련 서류를 제출하여야 한다.

② 인터넷진흥원은 제1항에 의해 제출한 신청서류가 자격 신청 요건에 적합한지를 검토하여야 한다.

③ 제2항에 따른 서류검토 결과 적합한 자는 인터넷진흥원이 시행하는 인증심사원 양성과정을 수료하여야 한다.

제14조(인증심사원 자격 발급 및 관리) ① 인터넷진흥원은 인증심사원 양성과정을 수료한 자에게 별지 제8호서식의 정보보호 및 개인정보보호 관리체계 인증심사원 자격 증명서를 발급하여야 한다.

② 인터넷진흥원은 인증심사원의 자격 증명서 발급, 심사원등급, 인증심사 업무경력 등을 관리하여야 한다.

제15조(인증심사원 자격 유지 및 갱신) ① 인증심사원의 자격 유효기간은 자격을 부여 받은 날부터 3년으로 한다.

② 인증심사원은 자격유지를 위해 자격 유효기간 만료 전까지 인터넷진흥원이 인정하는 보수교육을 수료하여야 한다.

③ 인터넷진흥원은 자격 유효기간 동안 1회 이상의 인증심사를 참여한 인증심사원에 대하여 제2항의 보수교육 시간 중 일부를 이수한 것으로 인정할 수 있다.

④ 인터넷진흥원은 인증정보를 제공하는 홈페이지에 제2항의 보수교육 운영에 관한 세부내용을 공지하여야 한다.

⑤ 인터넷진흥원은 제2항의 요건을 충족한 인증심사원에 한하여 별지 제8호서식의 정보보호 및 개인정보보호 관리체계 인증심사원 자격 증명서를 갱신하여 발급하고 자격 유효기간을 3년간 연장한다.

⑥ 제5항에도 불구하고 인터넷진흥원은 다음 각 호의 어느 하나에 해당하면 인증심사원 자격의 유효기간을 연장할 수 있다.

1. 제29조제2항에 따른 인증위원회 위원으로 인정된 자
2. 「재난 및 안전관리 기본법」 제3조에 따른 재난의 발생 등 협의회가 인정하는 불가피한 경우

제16조(인증심사원 자격 취소) ① 인터넷진흥원은 다음 각 호의 어느 하나에 해당하는 사유를 발견한 경우 인증심사원의 자격을 취소할 수 있다.

1. 거짓이나 부정한 방법으로 인증심사원 자격을 부여 받은 경우
2. 제15조제2항에 따른 자격 유지 기준을 충족하지 못한 경우
3. 인증심사원으로서 객관적이고 공정한 인증심사를 수행하지 않은 경우
4. 인증심사 과정에서 취득한 정보 또는 서류를 관련 법령의 근거나 인증신청인의 동의 없이 누설 또는 유출하거나 업무목적 외에 이를 사용한 경우

5. 인증신청인으로부터 금전, 금품, 향응, 이익 등을 부당하게 수수하거나 요구한 경우

② 인터넷진흥원의 장은 제1항에 따른 자격 취소의 적합여부를 심의·의결하기 위하여 자격심의위원회를 개최하여야 하며, 자격심의위원회는 제29조의 인증위원회 위원 3인 이상을 포함하여 구성한다.

③ 제1항에 따른 자격 취소에 대하여 인증심사원은 30일 이내에 이의신청을 할 수 있다. 이 경우 인터넷진흥원은 해당 인증심사원의 자격을 제2항의 절차에 따라 재심의하여 처리결과를 통지하여야 한다.

제5장 인증심사의 신청 및 수수료 납부

제17조(신청인의 사전 준비사항) ① 정보보호 및 개인정보보호 관리체계 인증을 취득하고자 하는 자(이하 "신청인"이라 한다)는 인증을 신청하기 전에 인증기준에 따른 정보보호 및 개인정보보호 관리체계 또는 정보보호 관리체계를 구축하여 최소 2개월 이상 운영하여야 한다. 다만, 제18조의2제1항제1호에 따른 예비인증의 경우에는 그러지 아니한다.

② 신청인은 인증심사를 위하여 다음 각 호의 사항을 인증심사 실시 전에 준비하여야 한다.

1. 인증심사를 위한 문서 및 증거자료
2. 인증심사 수행에 필요한 장소·시설·장비·기자재 등의 확보
3. 그 밖에 인증심사를 원활하게 수행하기 위하여 심사수행기관이 요구하는 사항

제18조(인증 신청 등) ① 신청인은 다음 각 호의 인증을 선택하여 신청할 수 있다.

1. 정보보호 및 개인정보보호 관리체계 인증
2. 정보보호 관리체계 인증

② 신청인은 제1항의 인증 선택에 따른 별지 제9호서식의 정보보호 및 개인정보보호 관리체계 인증 신청서를 심사수행기관에 제출하여야 한다.

③ 신청인은 인증범위 및 일정 등을 심사수행기관과 사전 협의하여 신청하여야 한다.

④ 심사수행기관은 제17조에 따른 신청인의 인증심사 사전준비사항을 확인할 수 있으며, 신청인의 준비가 미흡한 경우에는 신청인에 이를 보완할 것을 요구할 수 있다.

⑤ 심사수행기관은 인증범위의 변경이 필요한 경우에 이를 신청인과 협의하여 변경할 수 있다.

제18조의2(가상자산사업자에 대한 인증) ①「특정 금융거래정보의 보고 및 이용 등에 관한 법률」제7조제1항에 따라 신고를 하려는 가상자산사업자(가상자산사업을 운영하려는 자를 포함한다. 이하 이 조에서 같다)에 대한 제18조제1항제2호의 인증은 다음 각 호로 구분한다.

1. 예비인증: 가상자산사업자 중 본인증을 신청하기 전에 인증기준에 따른 정보보호 관리체계를 구축하여 2개월 이상 운영하지 못한 자가 실제 서비스 운영 전 임시적으로 관련 시스템을 구축·운영(이하 "시험운영"이라 한다)하여 받는 인증으로서 제2호에 따른 본인증을 받기 위한 조건부 인증
2. 본인증 : 예비인증을 취득한 자로서 인증을 신청하기 전에 인증기준에 따른 정보보호 관리체계를 구축하여 2개월 이상 운영한 자를 대상으로 하는 인증

② 인터넷진흥원 또는 인증기관은 가상자산사업자에게 제1항제1호에 따른 예비인증을 부여할 때에는 다음 각 호의 조건을 붙여야 한다.

1. 예비인증 취득한 날부터 3개월 이내에「특정 금융거래정보의 보고 및 이용 등에 관한 법률」제7조에 따른 신고를 할 것
2.「특정 금융거래정보의 보고 및 이용 등에 관한 법률」제7조에 따라 신고가 수리된 날부터 6개월 이내에 제1항제2호에 따른 본인증을 취득할 것(다만, 본인증 절차가 완료 될 때까지는 예비인증의 효력은 유효한 것으로 본다).

③ 예비인증 신청자가 제17조제2항에 따른 사전 준비사항을 준비하는 경우 정보보호 관리체계 구축 후에 시험운영 결과를 토대로 그 준비사항을 제출하여야 한다.

④ 인터넷진흥원 또는 인증기관은 제1항제1호에 따른 예비인증을 부여할 때에는 제32조에 따른 인증서 및 제34조에 따른 인증의 표시에 그 사실을 표기 및 표시하여야 한다.

⑤ 제1항제1호에 따른 예비인증은 제23조제1항제2호의 인증기준을 적용하되 시험운영을 통해 정보보호 관리체계가 적합한지에 대해 확인할 수 있는 범위로 한정한다.

제19조(정보보호 관리체계 인증 의무대상자) ① 정보보호 관리체계 인증 의무대상자(이하 "의무대상자"라 한다)란 정보통신망법 제47조제2항, 같은 법 시행령 제49조에 해당하는 자를 말한다.

② 제1항에 해당하는 자 중 집적정보통신시설 사업자가 마련한 시설의 일부를 임대하여 집적정보통신시설 사업을 하는 자에 대하여는 정보통신망법 시행령 제49조제2항의 기준을 준용한다.

③ 의무대상자는 제18조제1항제2호의 정보보호 관리체계 인증을 받아야 한다. 이때 의무대상자가 같은 항 제1호의 인증을 받은 경우에도 인증의무를 이행한 것으로 본다.

④ 의무대상자에 해당하는 자는 다음 해 8월 31일까지 인증을 받아야 한다.

⑤「재난 및 안전관리 기본법」제3조에 따른 재난의 발생 등 협의회가 인정하는 불가피한 사유로 제4항의 기한까지 인증을 받지 못한 경우 의무대상자의 인증 의무 이행 기한을 협의회가 정하는 바에 따라 연장할 수 있다.

제20조(인증심사의 일부 생략 신청 등) ① 제18조제1항 각 호의 어느 하나에 해당하는인증을 신청한 자가 다음 각 호의 어느 하나에 해당하는 인증을 받거나 정보보호 조치를 취한 경우 별표 5의 인증심사 일부 생략의 범위 내에서 인증심사의 일부를 생략할 수 있다.

1. 국제인정협력기구에 가입된 인정기관이 인정한 인증기관으로부터 받은 ISO/IEC 27001 인증
2.「정보통신기반 보호법」제9조에 따른 주요정보통신기반시설의 취약점 분석・평가

② 제1항에 따라 인증심사의 일부를 생략하려는 경우에는 다음 각 호의 요건을 모두 충족하여야 한다.

1. 제18조제1항 각 호의 어느 하나에 해당하는 인증의 범위에 해당 국제표준 정보보호 인증 또는 정보보호 조치의 범위가 포함될 것
2. 제18조제1항 각 호의 어느 하나에 해당하는 인증 신청 및 심사 시에 해당 국제표준 정보보호 인증이나 정보보호 조치가 유효하게 유지되고 있을 것

③ 제1항에 따른 인증심사 일부 생략을 신청하고자 하는 자는 별지 제10호서식의 인증심사 일부 생략 신청서를 심사수행기관에 제출하여야 한다.

④ 심사수행기관은 별표 5의 인증심사 일부 생략의 범위를 생략하여 심사하고 인터넷진흥원 또는 인증기관이 인증을 부여할 때에는 그 사실을 인증서에 표기하여야 한다.

⑤ 정보통신망법 시행규칙 제3조제3항에서 "과학기술정보통신부장관이 고시하는 결과"란「교육부 정보보안 기본지침」제94조제1항에 따른 정보보안 수준에 대한 해당 연도의 평가결과가 만점의 100분의 80 이상인 것을 말한다.

⑥ 심사수행기관은 신청인의 인증범위 내에서 업무를 위탁받아 처리하는 자가 제18조제1항 각 호의 인증을 받은 범위의 현장심사를 생략할 수 있다.

제21조(수수료의 산정) ① 인증 수수료는 별표 6의 인증 수수료 산정 및 심사원 보수 기준을 적용하여 산정한다.

② 심사수행기관은 제1항에 따라 산정된 인증 수수료를 공지하여야 한다.

③ 심사수행기관은 신청인이 다음 각 호의 어느 하나에 해당하는 경우 수수료를 감면 또는 조정할 수 있다.

1.「중소기업기본법」제2조제2항에 따른 소기업
2. 제20조에 따른 인증심사 일부 생략 신청을 하는 경우
3.「정보보호산업의 진흥에 관한 법률」제13조에 따라 정보보호 현황을 공시한 자
4. 정보통신망법 제47조의7제1항 각 호의 어느 하나에 해당하는 자로서 제23조제3항 및 제4항에 따른 인증심사 기준을 적용받는 경우
5. 그 밖에 신청인과 협의하여 수수료 조정이 필요하다고 판단되는 경우

제22조(수수료의 납부) 신청인은 최초심사, 사후심사 및 갱신심사 신청 시 인증 수수료를 청구 받은 날부터 인증심사 시작일 이전까지 심사수행기관에 납부하여야 하며, 수수료를 납부하지 않은 경우 심사수행기관은 인증심사를 실시하지 아니할 수 있다.

제6장 인증심사의 기준과 방법

제23조(인증심사 기준) ① 다음 각 호의 인증의 구분에 따라 별표 7의 인증기준을 적용한다.

1. 정보보호 및 개인정보보호 관리체계 인증 : 별표 7 가목부터 다목
2. 정보보호 관리체계 인증 : 별표 7 가목 및 나목

② 과학기술정보통신부장관과 보호위원회는 신청인과 협의를 통해 별표 7의 인증기준 내에서 인증범위, 업무특성, 기업규모 등을 고려하여 구체적인 확인사항을 관보 또는 인터넷 홈페이지에 공고할 수 있다.

③ 제1항에도 불구하고 정보통신망법 제47조의7제1항제1호 및 같은 법 시행령 제49조의2제1항제1호에 해당하는 자에 대해서는 다음 각 호의 인증의 구분에 따라 인증기준을 적용한다.

1. 정보보호 및 개인정보보호 관리체계 인증 : 별표 7의2 가목부터 다목
2. 정보보호 관리체계 인증 : 별표 7의2 가목(1.1.2. 항목 제외) 및 나목

④ 정보통신망법 시행령 제49조의2제1항제2호에 해당하는 자에 대해서는 다음 각 호의 인증의 구분에 따라 인증기준을 적용한다.

1. 정보보호 및 개인정보보호 관리체계 인증 : 별표 7의3 가목부터 다목
2. 정보보호 관리체계 인증 : 별표 7의3 가목 및 나목

제24조(인증심사팀 구성) ① 심사수행기관은 인증심사 일정이 확정된 때에는 인터넷진흥원에 심사원 모집을 요청하여 인증심사팀을 구성하여야 한다.

② 인증심사팀 구성 시 신청인의 인증범위, 사업유형, 기술의 다양성 등을 고려하여 심사팀원을 구성하여야 한다.

③ 인증심사원은 신청인의 정보보호 또는 개인정보보호 컨설팅에 참여하였거나 소속직원 등 신청인과 이해관계를 가지는 경우 사전에 소명하여야 하며, 심사수행기관은 인증심사원을 인증심사팀의 구성원에서 배제하여야 한다.

제25조(인증심사 방법 및 보완조치) ① 인증심사는 신청인을 방문하여 서면심사와 현장심사를 병행한다.

② 서면심사는 제23조에 따른 인증심사 기준에 적합한지에 대하여 정보보호 및 개인정보보호 관리체계 구축・운영 관련 정책, 지침, 절차 및 이행의 증거자료 검토, 정보보호대책 및 개인정보 처리단계별 요구사항 적용 여부 확인 등의 방법으로 관리적 요소를 심사한다.

③ 현장심사는 서면심사의 결과와 기술적・물리적 보호대책 이행여부를 확인하기 위하여 담당자 면담, 관련 시스템 확인 및 취약점 점검 등의 방법으로 기술적 요소를 심사한다.

④ 심사수행기관은 인증심사에서 발견된 결함에 대해 심사종료 다음날부터 최대 100일(재조치 요구 60일 포함) 이내에 보완조치를 완료하도록 신청인에게 요청할 수 있다.

⑤ 심사수행기관은 인증위원회 심의결과에 따라 인증위원회 종료 다음날부터 30일 이내에 신청인에게 추가 보완조치를 요구할 수 있다.

⑥ 제1항에도 불구하고「재난 및 안전관리 기본법」제3조에 따른 재난의 발생 등 협의회가 인정하는 불가피한 경우 원격심사를 병행할 수 있다.

제26조(심사중단) ① 심사수행기관은 다음 각 호의 사유가 발생한 경우에는 인증심사를 중단할 수 있다.

1. 신청인이 고의로 인증심사의 실시를 지연 또는 방해하거나 신청인의 귀책사유로 인하여 인증심사팀장이 인증심사를 계속 진행하기가 곤란하다고 판단하는 경우
2. 신청인이 제출한 관련 자료 등을 검토한 결과 인증심사를 받을 준비가 되었다고 볼 수 없는 경우
3. 인증심사 후 제25조제4항에 따른 보완조치를 최대 100일(재조치 요구 60일 포함) 이내에 완료하지 않은 경우
4.「재난 및 안전관리 기본법」제3조에 따른 재난의 발생 또는 경영환경 변화 등으로 인하여 인증심사 진행이 불가능하다고 판단되는 경우

② 심사수행기관은 제1항에 따라 인증심사를 중단하는 때에는 그 사유를 신청인에 서면으로 통보하여야 한다.

③ 심사수행기관은 제1항의 인증심사 중단 사유가 해소되거나 제36조에 따른 이의신청 처리결과에 따라 인증심사를 재개하거나 종결할 수 있다.

제27조(사후관리) ① 인증을 취득한 자는 인증서 유효기간 중 연 1회 이상 심사수행기관에 사후심사를 신청하여야 한다.

② 사후심사는 제5장 및 제6장을 준용하여 진행한다.

③ 인증 취득한 범위와 관련하여 침해사고 또는 개인정보 유출사고가 발생한 경우 인터넷진흥원은 필요에 따라 인증관련 항목의 보안향상을 위한 필요한 지원 등을 할 수 있다.

제28조(인증의 갱신) ① 인증을 취득한 자는 인증서 유효기간 만료 3개월 전에 갱신심사를 신청하여야 한다.

② 갱신심사는 제5장 및 제6장을 준용하여 진행한다.

③ 인증을 취득한 자가 제1항에 따른 인증의 갱신을 신청하지 않고 인증의 유효기간이 경과한 때에는 인증의 효력은 상실된다.

제7장 인증위원회 구성과 운영

제29조(인증위원회의 구성) ① 인터넷진흥원 또는 인증기관의 장은 다음 각 호의 사항을 심의·의결하기 위하여 인증위원회를 설치·운영하여야 한다.

1. 최초심사 또는 갱신심사 결과가 인증기준에 적합한지 여부
2. 제35조제1항에 따른 인증의 취소에 관한 사항
3. 제36조에 따른 이의신청에 관한 사항
4. 그 밖에 정보보호 및 개인정보보호 관리체계 인증과 관련하여 위원장이 필요하다고 인정하는 사항

② 인증위원회는 35인 이내의 위원으로 구성하되, 위원은 정보보호 및 개인정보보호 관련 분야에 학식과 경험이 있는 자 중에서 인터넷진흥원 또는 인증기관의 장이 위촉하며, 위원장은 위원 중에서 호선한다.

③ 위원장은 인증위원회의 업무를 통할하며 위원회를 대표한다.

④ 인터넷진흥원 또는 인증기관의 장은 위원이 법령 또는 이 규정을 위반한 때에는 해당 위원을 해촉할 수 있다.

제30조(인증위원회의 운영) ① 인증위원회의 회의는 인터넷진흥원 또는 인증기관의 요구로 개최하되, 회의마다 위원장과 인증위원의 전문분야를 고려하여 6인 이상의 인증위원으로 구성한다. 단, 위원장이 부득이한 사유로 직무를 수행할 수 없는 경우 위원장이 사전에 지명한 위원이 위원장의 직무를 대행한다.

② 인터넷진흥원 또는 인증기관의 장은 인증위원회의 심의안건을 검토하여 위원회 개최 5일 전까지 인증위원회에 제출한다. 다만, 긴급한 경우나 부득이한 사유가 있는 경우에는 그러하지 아니하다.

③ 인증위원회 위원장은 제29조제1항의 각 호의 사항에 대한 심의·의결 결과를 인터넷진흥원 또는 인증기관의 장에게 제출한다.

④ 인증위원회는 심의를 위하여 필요하다고 인정되는 경우에는 인증심사에 참여한 인증심사원 또는 관련 전문가로부터 그에 관한 의견을 들을 수 있다.

⑤ 인터넷진흥원 또는 인증기관의 장은 인증위원회의 심의·의결 결과를 제출받은 때에는 신청인에게 결과를 통보하여야 한다.

제31조(제척·기피·회피) ① 인증위원회 위원은 신청인과 다음 각 호의 사항 중 어느 하나에 해당하는 때에는 심의·의결에 관여할 수 없다.

1. 위원 본인과 직접적인 이해관계가 있는 사항
2. 위원 본인과 친족관계에 있거나 있었던 자와 관련된 사항
3. 위원이 되기 전에 감사·수사 또는 조사에 관여한 사항

② 위원에게 심의·의결의 공정을 기대하기 어려운 사정이 있는 경우 신청인은 기피신청을 할 수 있고, 위원회는 의결로 이를 결정한다.

③ 위원은 제척사유 또는 기피사유에 해당하는 경우에는 자기 스스로 심의·의결을 회피할 수 있다.

제8장 인증서의 발급·관리 및 홍보

제32조(인증서의 발급 등) ① 인터넷진흥원 또는 인증기관의 장은 인증위원회에서 인증적합으로 판정된 경우 그 결과에 따라 신청인에게 별지 제11호서식의 정보보호 및 개인정보보호 관리체계 인증서 또는 별지 제12호서식의 정보보호 관리체계 인증서를 발급하여야 한다.

② 인증서 발급 시 인증번호는 별표 8의 인증의 표시를 따른다.

③ 제1항에 따른 인증서의 유효기간은 3년으로 한다.

제33조(인증서 관리 및 재발급) ① 인터넷진흥원 또는 인증기관은 발급된 인증서의 인증번호, 발급일, 유효기간 등 인증서를 관리하여야 한다.

② 인증을 취득한 자는 인증서의 분실 등으로 인해 재발급을 받고자 할 경우 별지 제13호서식의 인증서 재발급 신청서를 인터넷진흥원 또는 인증기관에 제출하여야 한다.

③ 인증을 취득한 자가 주소, 업체명 등 인증서 기재사항의 변경을 요청하고자 하는 경우 별지 제14호서식의 인증서 변경 신청서를 인터넷진흥원 또는 인증기관에 제출하여야 한다.

제34조(인증의 표시 및 홍보) ①「개인정보 보호법 시행령」제34조의7 및 정보통신망법 시행령 제52조에 따른 인증의 표시는 별표 8과 같다.

② 제1항에 따른 인증의 표시를 사용하는 경우에는 인증범위 및 유효기간을 함께 표시하여야 한다.

③ 인터넷진흥원은 인증정보를 제공하는 홈페이지를 통해 인증현황을 공개하여야 한다.

제35조(인증의 취소) ① 인터넷진흥원 또는 인증기관은 다음 각 호의 사유를 발견한 때는 인증위원회 심의·의결을 거쳐 인증을 취소할 수 있다.

1. 거짓 혹은 부정한 방법으로 인증을 취득한 경우
2. 제23조에 따른 인증기준에 미달하게 된 경우
3. 인증을 취득한 자가 제27조제1항에 따른 사후심사 또는 제28조제1항에 따른 갱신심사를 받지 않았거나 제25조제4항에 따른 보완조치를 하지 않은 경우
4. 인증 받은 내용을 홍보하면서 제34조제2항에 따른 인증범위 및 유효기간을 허위로 표기하거나 누락한 경우
5. 인증을 취득한 자가 제27조 및 제28조에 따른 사후관리를 거부 또는 방해하는 경우

6. 개인정보보호 관련 법령을 위반하고 그 위반사유가 중대한 경우

② 인터넷진흥원 또는 인증기관은 제1항에 따라 인증을 취소한 경우에 그 결과를 통지하고, 제32조에 따라 발급한 인증서를 회수한다.

제36조(이의신청) ① 신청인 또는 인증을 취득한 자가 인증심사 결과 또는 인증 취소처분에 관하여 이의가 있는 때에는 그 결과를 통보받은 날부터 15일 이내에 별지 제15호서식의 이의신청서를 인터넷진흥원 또는 인증기관에 제출하여야 한다.

② 인터넷진흥원 또는 인증기관은 제1항에 따른 이의신청이 이유가 있다고 인정되는 경우에는 인증위원회에 재심의를 요청할 수 있다.

③ 인터넷진흥원 또는 인증기관은 이의신청에 대한 처리결과를 신청인 또는 인증을 취득한 자에 통지하여야 한다.

제9장 인증업무 일반 등

제37조(비밀유지 등) ① 인터넷진흥원, 인증기관, 심사기관, 인증위원회 위원, 인증심사원 등 인증심사 업무에 종사하는 자 또는 종사하였던 자는 정당한 권한 없이 또는 허용된 권한을 초과하여 업무상 지득한 비밀에 관한 정보를 누설하거나 이를 업무 목적 이외에 사용하여서는 아니 된다.

② 인터넷진흥원, 인증기관, 심사기관, 인증위원회 위원, 인증심사원 등 인증심사 업무에 종사하는 자 또는 종사하였던 자는 인증에 관련하여 일체의 금전, 금품, 이익 등을 부당하게 수수하여서는 아니 된다.

제38조(업무 지침 등) 인터넷진흥원, 인증기관 또는 심사기관은 인증 또는 심사업무 수행을 위해 필요한 경우 법령의 범위 내에서 인증 또는 심사업무에 관한 지침을 마련하여 시행할 수 있다.

제39조(재검토 기한) 과학기술정보통신부장관과 보호위원회는「행정규제기본법」및「훈령·예규 등의 발령 및 관리에 관한 규정」에 따라 이 고시에 대하여 2019년 1월 1일을 기준으로 매3년이 되는 시점(매 3년째의 12월 31일까지를 말한다)마다 그 타당성을 검토하여 개선 등의 조치를 하여야 한다.

부칙 <제2024-8호,2024.7.24.>

이 고시는 발령한 날부터 시행한다.